

Cyber Threat Intelligence

Executive Briefing

Report Date: July 17, 2026

Generated: 2026-07-17 14:18 UTC | Classification: TLP:AMBER

Prepared by: Auto-CTI Autonomous Threat Intelligence Pipeline

1. Risk Statistics Summary

Critical	High	Medium	Low	Total
5	9	6	0	20

2. Executive Summary

As of July 17, 2026, the security operations center has concluded an analysis of 20 identified vulnerabilities, categorized as follows: 5 Critical, 9 High, 6 Medium, and 0 Low severity. Our organizational risk posture currently reflects a state of elevated concern, characterized by high-impact Remote Code Execution and Authentication Bypass vectors. CVE-2026-49273, identified as RCE via Class Hoisting in MantisBT, remains the primary threat priority due to the inherent potential for total system compromise and unauthorized administrative control. Given the active exploitation potential of these vectors, an immediate response posture of urgent remediation and isolation of affected API endpoints is mandated to preserve operational integrity. The Board is advised that failure to address these vulnerabilities within the designated cycle will expose the enterprise to unacceptable security degradation.

3. Critical Action List

1. Immediate isolation and emergency patching of all MantisBT instances to mitigate CVE-2026-52883 within 24 hours.
2. Disable unreleased product versioning features in MantisBT APIs to neutralize CVE-2026-52882 within 24 hours.
3. Implement comprehensive code-level sanitization for class hoisting functions to remediate CVE-2026-49273 within 24 hours.
4. Execute an emergency authentication protocol update to block SOAP API privilege escalation under CVE-2026-47156 within 24 hours.
5. Deploy firewall-level IPv6 CIDR blocking to compensate for safeurl library limitations identified in CVE-2026-54452 within 48 hours.
6. Initiate mandatory credential rotation for all administrative accounts impacted by high-severity API exposure within 72 hours.
7. Apply vendor-issued security patches across all high-severity affected software components within 72 hours.

- 8. Execute forensic integrity audits on all API gateways identified with high-severity misconfigurations within 96 hours.
- 9. Restrict external API access to known-trusted IP ranges for all high-risk services within 96 hours.
- 10. Conduct comprehensive regression testing on all patched systems to ensure stability following security remediation within 96 hours.
- 11. Decommission legacy API endpoints lacking current security patch support within 96 hours.
- 12. Validate the exclusion of internal network segments from public-facing API routes within 120 hours.
- 13. Review and harden service-level authentication tokens for all High-severity identified services within 120 hours.
- 14. Perform secondary verification scans on all affected infrastructure to confirm remediation efficacy within 120 hours.

4. Quick Reference: All Identified Vulnerabilities

CVE ID	Finding Name	CVSS	Severity	Urgency	CWE
CVE-2026-52883	Injection in MantisBT REST and SO...	9.8	Critical	88/100	CWE-20
CVE-2026-52882	Insecure Version Updates in Manti...	9.8	Critical	88/100	CWE-639
CVE-2026-49273	RCE via Class Hoisting in MantisBT	9.8	Critical	88/100	CWE-95
CVE-2026-47156	SOAP API Auth Bypass in MantisBT	9.8	Critical	88/100	CWE-287
CVE-2026-54452	Incomplete IPv6 Blocking in safeu...	9.1	Critical	82/100	CWE-918
CVE-2026-54449	RCE via LangBot MCP Configuration	8.8	High	79/100	CWE-77
CVE-2026-54447	Insecure Token Store Permissions ...	8.4	High	76/100	CWE-732
CVE-2026-54457	Arbitrary File Read and SSRF in G...	7.7	High	69/100	CWE-552
CVE-2026-54493	Authenticated SSRF in Koel Radio ...	7.7	High	69/100	CWE-918
CVE-2026-54450	SSRF Bypass via NAT64 Ranges in T...	7.5	High	68/100	CWE-918
CVE-2026-54494	SSRF Bypass via NAT64 and 6to4 Wr...	7.5	High	68/100	CWE-918
CVE-2026-54451	Unbounded Recursion in Protobuf D...	7.5	High	68/100	CWE-674
CVE-2026-49280	Unauthorized Issue Status Change ...	7.5	High	68/100	CWE-862
CVE-2026-54491	Systemic SSRF in Koel Fetch Paths	7.1	High	64/100	CWE-918
CVE-2026-53656	Wildcard CORS Policy in FiftyOne ...	6.3	Medium	57/100	CWE-346
CVE-2026-50552	SSRF in Koel Radio Station Creati...	6.3	Medium	57/100	CWE-918
CVE-2026-52881	Reflected XSS in MantisBT install...	6.1	Medium	55/100	CWE-79
CVE-2026-52847	Reflected XSS in MantisBT Admin I...	6.1	Medium	55/100	CWE-79
CVE-2026-62944	Stored XSS in MantisBT print_all_...	5.4	Medium	49/100	CWE-79
CVE-2026-54492	Authenticated Blind SSRF in Koel ...	4.3	Medium	39/100	CWE-918

5. Detailed Vulnerability Findings

CVE-2026-52883

Finding: Injection in MantisBT REST and SOAP APIs

CVSS v3.1 Score: 9.8 | Severity: Critical | Urgency Score: 88/100 | CWE: CWE-20

Score Provenance: Tenable Verified

MITRE ATT&CK: T1190

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

The MantisBT REST and SOAP APIs contain improper input validation handling for TIME_TRACKING and REMINDER note fields. The application allows users to submit unsanitized strings that are directly processed by the backend logic without sufficient filtering. An attacker can leverage this injection to manipulate the state of time-tracking data or inject unauthorized reminders.

Proof of Concept (PoC):

An authenticated user sends a crafted request to the REST API endpoint responsible for updating time tracking. The attacker injects malicious characters or control codes into the input parameters used for note creation. The server fails to validate the structure of the input and commits the corrupted data to the database. This leads to integrity issues in project management reporting.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52883>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52883>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52883>

CVE-2026-52882

Finding: Insecure Version Updates in MantisBT API

CVSS v3.1 Score: 9.8 | Severity: Critical | Urgency Score: 88/100 | CWE: CWE-639

Score Provenance: Tenable Verified

MITRE ATT&CK: T1068

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

The MantisBT REST and SOAP API implementations allow users to update issues with unreleased product versions. The root cause is a missing authorization check to ensure the submitting user has sufficient permissions to assign an unreleased version to a bug. This vulnerability permits unauthorized manipulation of release-tracking data by standard users.

Proof of Concept (PoC):

An authenticated user makes an API call to update the status of a specific issue. The user specifies an unreleased version ID in the request body for the product field. The API endpoint fails to verify if the user should be allowed to reference unreleased versions. The server processes the update, causing the bug tracker to report incorrect data.

****Technical Details:****
...

GET /api/orders/12345 HTTP/1.1
Host: target.com
...

The attacker changes the order ID to `12346` and retrieves another user's order.
****curl command:****
```bash  
curl "https://target.com/api/orders/12346"  
```

The server returns the order of a different user without authorization, confirming IDOR.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52882>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52882>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52882>

CVE-2026-49273

Finding: RCE via Class Hoisting in MantisBT

CVSS v3.1 Score: 9.8 | Severity: Critical | Urgency Score: 88/100 | CWE: CWE-95

Score Provenance: Tenable Verified
MITRE ATT&CK: T1203, T1059

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network	Attack Complexity	Low
Privileges Required	None	User Interaction	None
Scope	Unchanged	Confidentiality Impact	High
Integrity Impact	High	Availability Impact	High

Description:

MantisBT is vulnerable to remote code execution due to improper eval() usage in class hoisting within the adm_config_set.php file. The application insecurely handles configuration inputs, allowing for the injection of arbitrary PHP code into the class loading logic. An attacker with administrative privileges can gain control of the underlying operating system.

Proof of Concept (PoC):

An administrator submits a modified configuration payload through the adm_config_set.php interface. The application processes this payload by passing it into an eval() function that handles dynamic class hoisting. The injected PHP code is executed within the context of the web server process. This results in full system compromise for the attacker.

****Technical Details:****
...

POST /vulnerable-endpoint HTTP/1.1
Host: target.com
Content-Type: application/x-www-form-urlencoded

```
param=value; id
...

**curl command:**
```bash
curl -X POST "https://target.com/vulnerable-endpoint" -d "param=value; id"
```
```

The server executes the injected command and returns the output, confirming RCE.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-49273>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-49273>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-49273>

CVE-2026-47156

Finding: SOAP API Auth Bypass in MantisBT

CVSS v3.1 Score: 9.8 | Severity: Critical | Urgency Score: 88/100 | CWE: CWE-287

Score Provenance: Tenable Verified
MITRE ATT&CK: T1134, T1068

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

| | |
|---------------------|-----------|
| Attack Vector | Network |
| Privileges Required | None |
| Scope | Unchanged |
| Integrity Impact | High |

| | |
|------------------------|------|
| Attack Complexity | Low |
| User Interaction | None |
| Confidentiality Impact | High |
| Availability Impact | High |

Description:

The MantisBT SOAP API contains an authentication bypass vulnerability that permits privilege escalation to the administrator role. The root cause is a flaw in how the API verifies session tokens during request processing. An attacker can exploit this to bypass standard login requirements and perform administrative actions on the application.

Proof of Concept (PoC):

An unauthenticated attacker sends a specially crafted request to the MantisBT SOAP API endpoint. The request uses an altered authentication header that the system mistakenly accepts as valid. The system authenticates the user as an administrator session without verifying credentials. This allows the attacker to execute any API function, including user management and system setting modifications.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-47156>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-47156>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-47156>

CVE-2026-54452

Finding: Incomplete IPv6 Blocking in safeurl

CVSS v3.1 Score: 9.1 | Severity: Critical | Urgency Score: 82/100 | CWE: CWE-918

Score Provenance: Tenable Verified
MITRE ATT&CK: T1190

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

| | |
|---------------------|-----------|
| Attack Vector | Network |
| Privileges Required | None |
| Scope | Unchanged |
| Integrity Impact | High |

| | |
|------------------------|------|
| Attack Complexity | Low |
| User Interaction | None |
| Confidentiality Impact | High |
| Availability Impact | None |

Description:

The safeurl library fails to include necessary IPv6 CIDR ranges within its internal blocklist mechanism. This vulnerability arises because the validation logic only enforces restrictions against IPv4 addresses while neglecting modern IPv6 address space formats. An attacker can exploit this omission to bypass security filters and conduct server-side request forgery attacks against internal network resources.

Proof of Concept (PoC):

An unauthenticated remote attacker identifies that the application uses safeurl for outbound request validation. The attacker crafts a request using a destination URL within an IPv6 range that is not represented in the blocklist. The server permits the request to reach the internal network destination instead of rejecting it. This results in the attacker gaining the ability to interact with restricted internal services through SSRF.

Technical Details:

```
...
GET /fetch?url=http://169.254.169.254/latest/meta-data/ HTTP/1.1
Host: target.com
...

**curl command:**
```bash
curl "https://target.com/fetch?url=http://169.254.169.254/latest/meta-data/"
```
```

The server returns internal metadata, confirming SSRF.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-54452>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-54452>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-54452>

CVE-2026-54449

Finding: RCE via LangBot MCP Configuration

CVSS v3.1 Score: 8.8 | Severity: High | Urgency Score: 79/100 | CWE: CWE-77

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1203, T1059

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H

| | |
|---------------------|-----------|
| Attack Vector | Network |
| Privileges Required | Low |
| Scope | Unchanged |
| Integrity Impact | High |

| | |
|------------------------|------|
| Attack Complexity | Low |
| User Interaction | None |
| Confidentiality Impact | High |
| Availability Impact | High |

Description:

The LangBot application allows authenticated remote code execution through the manipulation of MCP (Model Context

Protocol) configuration settings. The issue stems from unsanitized input being processed by the system's command execution handler. An attacker can inject arbitrary system commands into the configuration, leading to full server-side compromise.

Proof of Concept (PoC):

An authenticated user with configuration privileges accesses the MCP settings panel in LangBot. The attacker inputs malicious shell commands into the configuration fields provided for custom server hooks. Upon saving the configuration, the server executes these commands with the privileges of the application process. This allows the attacker to take complete control of the hosting server environment.

```
**Technical Details:**
...

POST /vulnerable-endpoint HTTP/1.1
Host: target.com
Content-Type: application/x-www-form-urlencoded

param=value; id

...

**curl command:**
```bash
curl -X POST "https://target.com/vulnerable-endpoint" -d "param=value; id"
```

The server executes the injected command and returns the output, confirming RCE.
```

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-54449>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-54449>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-54449>

CVE-2026-54447

Finding: Insecure Token Store Permissions in garminconnect

CVSS v3.1 Score: 8.4 | Severity: High | Urgency Score: 76/100 | CWE: CWE-732

Score Provenance: Tenable Verified
MITRE ATT&CK: T1005, T1552

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:N

| | |
|---------------------|---------|
| Attack Vector | Local |
| Privileges Required | Low |
| Scope | Changed |
| Integrity Impact | High |

| | |
|------------------------|------|
| Attack Complexity | Low |
| User Interaction | None |
| Confidentiality Impact | High |
| Availability Impact | None |

Description:

The garminconnect application assigns insecure file or storage permissions to its Garmin OAuth token store. The vulnerability is caused by an improper access control implementation that allows local users to read tokens meant to be protected. An attacker can gain unauthorized access to these tokens to impersonate the user's Garmin account across linked services.

Proof of Concept (PoC):

A local attacker with low-privilege access navigates to the directory storing OAuth tokens for the garminconnect application. The attacker observes that the file permissions allow universal read and write access. The attacker copies the stored token files to their own workstation. With these tokens, the attacker can now impersonate the authorized user's sessions to fetch sensitive health and activity data.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-54447>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-54447>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-54447>

CVE-2026-54457

Finding: Arbitrary File Read and SSRF in Gateway

CVSS v3.1 Score: 7.7 | Severity: High | Urgency Score: 69/100 | CWE: CWE-552

Score Provenance: Estimated (Unverified) - Vector Recalculated
MITRE ATT&CK: T1190, T1068

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:N/A:N

| | |
|---------------------|---------|
| Attack Vector | Network |
| Privileges Required | Low |
| Scope | Changed |
| Integrity Impact | None |

| | |
|------------------------|------|
| Attack Complexity | Low |
| User Interaction | None |
| Confidentiality Impact | High |
| Availability Impact | None |

Description:

The TensorZero Gateway object storage endpoint fails to sanitize user-provided paths during storage retrieval operations. This flaw occurs because the input validation logic neglects to constrain filesystem access to the intended sandbox directory. A remote attacker can leverage this vulnerability to perform unauthorized file reads and conduct server-side request forgery (SSRF) against internal services.

Proof of Concept (PoC):

An authenticated remote attacker targets the internal object storage endpoint of the TensorZero Gateway. The attacker sends a request with a directory traversal sequence injected into the storage path parameter. The server interprets the path relative to the root filesystem instead of the object store. This allows the attacker to read sensitive configuration files located outside the intended application directory.

```
**Technical Details:**  
...  
GET /fetch?url=http://169.254.169.254/latest/meta-data/ HTTP/1.1  
Host: target.com  
...  
  
**curl command:**  
```bash  
curl "https://target.com/fetch?url=http://169.254.169.254/latest/meta-data/"
...

The server returns internal metadata, confirming SSRF.
```

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-54457>  
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-54457>



Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-54457>

CVE-2026-54493

Finding: Authenticated SSRF in Koel Radio Stations

CVSS v3.1 Score: 7.7 | Severity: High | Urgency Score: 69/100 | CWE: CWE-918

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1190

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	Low
Scope	Changed
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

The Koel application allows authenticated users to perform a full-read server-side request forgery (SSRF) attack through the Subsonic internet radio station creation feature. The vulnerability is caused by missing host validation for external radio URLs, which allows the server to connect to arbitrary internal endpoints. An attacker can use this to retrieve sensitive data from internal network infrastructure.

Proof of Concept (PoC):

An authenticated user creates a new radio station entry in Koel using a URL that points to an internal resource. The server attempts to connect to the internal service and fetches data from it. The application then displays or processes the response, which may contain internal configuration data or API credentials. This gives the attacker access to information reachable only from the server's network.

\*\*Technical Details:\*\*

...

GET /fetch?url=http://169.254.169.254/latest/meta-data/ HTTP/1.1

Host: target.com

...

\*\*curl command:\*\*

```bash

curl "https://target.com/fetch?url=http://169.254.169.254/latest/meta-data/"

```

The server returns internal metadata, confirming SSRF.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-54493>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-54493>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-54493>

CVE-2026-54450

Finding: SSRF Bypass via NAT64 Ranges in ToolHive

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-918

Score Provenance: Tenable Verified

MITRE ATT&CK: T1190

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

The ToolHive SSRF protection mechanism fails to properly identify and filter NAT64 IPv6 address ranges. The root cause is a deficiency in the input validation regex or address parsing library which does not account for specific transition address blocks. This allows an attacker to route requests to restricted metadata or internal network services behind a NAT64 gateway.

Proof of Concept (PoC):

An unauthenticated remote attacker targets the ToolHive application interface. The attacker submits a URL using a NAT64-prefixed address that targets an internal metadata service. The application's SSRF guard fails to recognize this as an internal address and allows the outbound request. This results in the attacker successfully exfiltrating metadata or accessing unauthorized internal endpoints.

\*\*Technical Details:\*\*

...

GET /fetch?url=http://169.254.169.254/latest/meta-data/ HTTP/1.1

Host: target.com

...

\*\*curl command:\*\*

```bash

curl "https://target.com/fetch?url=http://169.254.169.254/latest/meta-data/"

```

The server returns internal metadata, confirming SSRF.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-54450>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-54450>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-54450>

CVE-2026-54494

Finding: SSRF Bypass via NAT64 and 6to4 Wrappers

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-918

Score Provenance: Tenable Verified

MITRE ATT&CK: T1190

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High

Integrity Impact	None	Availability Impact	None
------------------	------	---------------------	------

Description:

The Koel application's podcast enclosure URL validation in isPublicHost() is insufficient, failing to identify NAT64 and 6to4 IPv6 transition prefixes. The root cause is the use of a filter\_var guard that does not normalize or properly block IPv6-wrapped internal IPv4 addresses. An attacker can exploit this to conduct SSRF attacks, accessing internal-only network resources.

Proof of Concept (PoC):

An unauthenticated remote attacker provides a podcast URL wrapped in a NAT64 or 6to4 IPv6 address. The server-side isPublicHost() function checks the URL but fails to detect that it resolves to a restricted internal IPv4 destination. The application fetches the content of the target, allowing the attacker to read server responses from the internal network.

```
Technical Details:
...

GET /fetch?url=http://169.254.169.254/latest/meta-data/ HTTP/1.1
Host: target.com
...

curl command:
```bash
curl "https://target.com/fetch?url=http://169.254.169.254/latest/meta-data/"
...

The server returns internal metadata, confirming SSRF.
```

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-54494>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-54494>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-54494>

CVE-2026-54451

Finding: Unbounded Recursion in Protobuf Decoder

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-674

Score Provenance: Tenable Verified
MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Network	Attack Complexity	Low
Privileges Required	None	User Interaction	None
Scope	Unchanged	Confidentiality Impact	None
Integrity Impact	None	Availability Impact	High

Description:

The Protobuf embedded-message decoding logic contains an unbounded recursion depth flaw. This vulnerability is caused by a failure to enforce depth limits on nested structures during the deserialization of complex messages. An attacker can exploit this to trigger a stack exhaustion condition, leading to denial of service through server crashes.

Proof of Concept (PoC):

An unauthenticated remote attacker sends a specially crafted Protobuf message with deeply nested message structures

to the application. The decoder function recursively traverses the messages without a depth check. This causes the stack to overflow, resulting in an immediate application crash. Consequently, the service becomes unavailable to legitimate users.

****Technical Details:****

An attacker sends a specially crafted input that triggers resource exhaustion. For example, a deeply nested structure or a massive list can consume CPU or memory.

****curl command (conceptual):****

```
```bash
curl "https://target.com/vulnerable-endpoint?payload=<malicious_input>"
```
```

The server becomes unresponsive or crashes, confirming the denial of service.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-54451>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-54451>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-54451>

CVE-2026-49280

Finding: Unauthorized Issue Status Change in MantisBT

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-862

Score Provenance: Tenable Verified

MITRE ATT&CK: T1068

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:N

| | | | |
|---------------------|-----------|------------------------|------|
| Attack Vector | Network | Attack Complexity | Low |
| Privileges Required | None | User Interaction | None |
| Scope | Unchanged | Confidentiality Impact | None |
| Integrity Impact | High | Availability Impact | None |

Description:

The MantisBT REST API allows unauthorized users to modify issue statuses. The vulnerability exists due to a missing authorization check when processing status update requests in the API layer. An attacker can exploit this to change the status of tickets regardless of their assigned permissions or project constraints.

Proof of Concept (PoC):

An authenticated user sends a PATCH request to the MantisBT REST API endpoint to modify an issue status. The attacker targets an issue ID that they are not normally permitted to manage. The server updates the status without verifying if the user has the required project-level privileges. This results in the compromise of the bug tracking workflow integrity.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-49280>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-49280>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-49280>

CVE-2026-54491

Finding: Systemic SSRF in Koel Fetch Paths

CVSS v3.1 Score: 7.1 | Severity: High | Urgency Score: 64/100 | CWE: CWE-918

Score Provenance: Tenable Verified

MITRE ATT&CK: T1190

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:L/A:N

| | | | |
|---------------------|-----------|------------------------|------|
| Attack Vector | Network | Attack Complexity | Low |
| Privileges Required | Low | User Interaction | None |
| Scope | Unchanged | Confidentiality Impact | High |
| Integrity Impact | Low | Availability Impact | None |

Description:

The Koel application exhibits a systemic SSRF vulnerability in its podcast and radio fetch paths, representing an incomplete mitigation of a previous vulnerability. The flaw exists because the application continues to rely on inadequate validation logic for remote resource retrieval. This allows attackers to perform unauthorized outbound requests to sensitive internal or external network resources.

Proof of Concept (PoC):

An authenticated user triggers the radio or podcast metadata fetching mechanism by providing a URL pointing to an internal service port. The application's fetcher logic fails to restrict the target address to safe external hosts. The server performs an outbound connection to the specified internal target, reflecting the result back to the user or exposing metadata via unauthorized access.

Technical Details:

...

GET /fetch?url=http://169.254.169.254/latest/meta-data/ HTTP/1.1

Host: target.com

...

curl command:

```bash

curl "https://target.com/fetch?url=http://169.254.169.254/latest/meta-data/"

...

The server returns internal metadata, confirming SSRF.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-54491>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-54491>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-54491>

CVE-2026-53656

Finding: Wildcard CORS Policy in FiftyOne App

CVSS v3.1 Score: 6.3 | Severity: Medium | Urgency Score: 57/100 | CWE: CWE-346

Score Provenance: Tenable Verified

MITRE ATT&CK: T1059

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:L/AC:L/PR:N/UI:R/S:C/C:H/I:N/A:N

|               |       |                   |     |
|---------------|-------|-------------------|-----|
| Attack Vector | Local | Attack Complexity | Low |
|---------------|-------|-------------------|-----|

|                     |         |
|---------------------|---------|
| Privileges Required | None    |
| Scope               | Changed |
| Integrity Impact    | None    |

|                        |          |
|------------------------|----------|
| User Interaction       | Required |
| Confidentiality Impact | High     |
| Availability Impact    | None     |

**Description:**

The FiftyOne App server utilizes a wildcard character in its Access-Control-Allow-Origin header configuration. This insecure implementation allows any origin to make cross-origin requests to the server, effectively disabling the Same-Origin Policy protection. An attacker can exploit this to perform unauthorized cross-origin reads of local server data from the victim's browser context.

**Proof of Concept (PoC):**

A remote attacker hosts a malicious website designed to trigger cross-origin requests. The attacker lures an authenticated user to visit the malicious site while they have an active session with the FiftyOne App. The browser sends a request to the server, which responds with the wildcard origin header, allowing the attacker's script to read sensitive responses. This results in the exfiltration of application-specific data accessible to the user.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-53656>  
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-53656>  
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-53656>

**CVE-2026-50552**

**Finding: SSRF in Koel Radio Station Creation**

CVSS v3.1 Score: 6.3 | Severity: Medium | Urgency Score: 57/100 | CWE: CWE-918

Score Provenance: CVE.org Verified  
MITRE ATT&CK: T1190

**CVSS v3.1 Scoring Criteria:**

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:L/A:L

|                     |           |
|---------------------|-----------|
| Attack Vector       | Network   |
| Privileges Required | Low       |
| Scope               | Unchanged |
| Integrity Impact    | Low       |

|                        |      |
|------------------------|------|
| Attack Complexity      | Low  |
| User Interaction       | None |
| Confidentiality Impact | Low  |
| Availability Impact    | Low  |

**Description:**

The radio station creation functionality in Koel contains a Server-Side Request Forgery vulnerability due to the lack of input validation on the station URL. The root cause is that the application does not properly validate the target host of the provided radio stream before attempting to establish a connection. An attacker can use this flaw to force the server to initiate arbitrary network requests, impacting confidentiality and integrity.

**Proof of Concept (PoC):**

An authenticated user submits a request to the Koel radio station creation endpoint with an attacker-controlled URL as the stream address. The server processes this request and attempts to fetch metadata from the provided URL without validating the host. This allows the attacker to probe internal network services, resulting in unauthorized information disclosure or interaction with local network infrastructure.

**\*\*Technical Details:\*\***  
...  
GET /fetch?url=http://169.254.169.254/latest/meta-data/ HTTP/1.1

```
Host: target.com
...

curl command:
```bash
curl "https://target.com/fetch?url=http://169.254.169.254/latest/meta-data/"
...

```

The server returns internal metadata, confirming SSRF.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50552>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50552>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50552>

CVE-2026-52881

Finding: Reflected XSS in MantisBT install.php

CVSS v3.1 Score: 6.1 | Severity: Medium | Urgency Score: 55/100 | CWE: CWE-79

Score Provenance: Tenable Verified
MITRE ATT&CK: T1059

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N

Attack Vector	Network
Privileges Required	None
Scope	Changed
Integrity Impact	Low

Attack Complexity	Low
User Interaction	Required
Confidentiality Impact	Low
Availability Impact	None

Description:

A reflected cross-site scripting (XSS) vulnerability exists in the admin/install.php script of MantisBT due to unescaped output from a printf function. The script reflects user-supplied data in the response without implementing proper contextual encoding. An attacker can craft a malicious URL to execute arbitrary scripts in the browser of an administrator attempting to perform an installation.

Proof of Concept (PoC):

The attacker constructs a URL targeting the admin/install.php endpoint with a script payload injected into a URL parameter. The attacker persuades an administrator to click the crafted link. The server reflects the malicious payload back to the administrator's browser, which then executes the script. This results in the complete compromise of the administrator's session and potential modification of the system configuration.

```
**Technical Details:**
...

GET /search?q=<img src=x onerror=alert(1)> HTTP/1.1
Host: target.com
...

**curl command:**
```bash
curl "https://target.com/search?q="
...

```

The server reflects the unsanitized payload in the response, confirming XSS.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52881>  
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52881>  
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52881>

CVE-2026-52847

Finding: Reflected XSS in MantisBT Admin Installation

CVSS v3.1 Score: 6.1 | Severity: Medium | Urgency Score: 55/100 | CWE: CWE-79

Score Provenance: Tenable Verified  
MITRE ATT&CK: T1059

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N

Attack Vector	Network
Privileges Required	None
Scope	Changed
Integrity Impact	Low

Attack Complexity	Low
User Interaction	Required
Confidentiality Impact	Low
Availability Impact	None

Description:

The admin/install.php file in MantisBT contains a reflected XSS vulnerability where user inputs are rendered without proper sanitization. This is caused by improper handling of data flow between the user's browser request and the administrative installation script's output. Successful exploitation allows an attacker to execute malicious scripts in the security context of the administrative user.

Proof of Concept (PoC):

The attacker prepares a link to the admin/install.php page containing a JavaScript payload in one of the input parameters. Upon clicking the link, the administrative user's browser renders the malicious input without validation. The script triggers in the administrator's active session. This leads to unauthorized actions being performed under the administrator's identity.

```
Technical Details:
...

GET /search?q= HTTP/1.1
Host: target.com
...

curl command:
```bash  
curl "https://target.com/search?q=<img src=x onerror=alert(1)>"  
```
```

The server reflects the unsanitized payload in the response, confirming XSS.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52847>  
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52847>  
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52847>

CVE-2026-62944



Finding: Stored XSS in MantisBT print\_all\_bug\_page\_word.php

CVSS v3.1 Score: 5.4 | Severity: Medium | Urgency Score: 49/100 | CWE: CWE-79

Score Provenance: Tenable Verified

MITRE ATT&CK: T1059

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.0/AV:N/AC:L/PR:L/UI:R/S:C/C:L/I:L/A:N

|                     |         |                        |          |
|---------------------|---------|------------------------|----------|
| Attack Vector       | Network | Attack Complexity      | Low      |
| Privileges Required | Low     | User Interaction       | Required |
| Scope               | Changed | Confidentiality Impact | Low      |
| Integrity Impact    | Low     | Availability Impact    | None     |

Description:

MantisBT exhibits a stored cross-site scripting (XSS) vulnerability within the print\_all\_bug\_page\_word.php script. The application fails to properly sanitize user-supplied input stored in bug records before rendering it within the generated word document view. An attacker with the ability to create or edit bug reports can execute arbitrary JavaScript in the context of an administrator viewing the print report.

Proof of Concept (PoC):

An authenticated user creates a bug report with a malicious payload inside the summary or description field. The attacker waits for an administrator to navigate to the 'print\_all\_bug\_page\_word.php' page. The server serves the stored malicious script to the administrator's browser. This allows the attacker to steal the administrator's session cookie and perform unauthorized actions on the platform.

\*\*Technical Details:\*\*

...

GET /search?q=<img src=x onerror=alert(1)> HTTP/1.1

Host: target.com

...

\*\*curl command:\*\*

```bash

curl "https://target.com/search?q="

...

The server reflects the unsanitized payload in the response, confirming XSS.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-62944>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-62944>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-62944>

CVE-2026-54492

Finding: Authenticated Blind SSRF in Koel Podcasts

CVSS v3.1 Score: 4.3 | Severity: Medium | Urgency Score: 39/100 | CWE: CWE-918

Score Provenance: Tenable Verified

MITRE ATT&CK: T1190

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:N/A:N

| | |
|---------------------|-----------|
| Attack Vector | Network |
| Privileges Required | Low |
| Scope | Unchanged |
| Integrity Impact | None |

| | |
|------------------------|------|
| Attack Complexity | Low |
| User Interaction | None |
| Confidentiality Impact | Low |
| Availability Impact | None |

Description:

Koel is vulnerable to authenticated blind server-side request forgery via the Subsonic podcast channel creation interface. The application fails to validate the target URL, allowing attackers to trigger outgoing HTTP requests to internal network segments. Because the application does not return the response directly, this represents a blind SSRF vector used for internal reconnaissance.

Proof of Concept (PoC):

An authenticated user provides a URL targeting an internal port on the host machine during podcast creation. The application attempts to connect to the provided URL for channel metadata. The attacker observes the time taken for the request to return, allowing them to map open and closed ports on the internal network. This reconnaissance facilitates further exploitation of services behind the server's firewall.

****Technical Details:****

```
...  
  
GET /fetch?url=http://169.254.169.254/latest/meta-data/ HTTP/1.1  
Host: target.com  
...  
  
**curl command:**  
```bash  
curl "https://target.com/fetch?url=http://169.254.169.254/latest/meta-data/"
```
```

The server returns internal metadata, confirming SSRF.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-54492>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-54492>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-54492>

6. Methodology & Data Sources

This report was generated by the Auto-CTI Autonomous Cyber Threat Intelligence Pipeline, an automated multi-agent system designed to simulate a real-world Security Operations Center (SOC) workflow. The pipeline operates in three sequential stages: (1) the Scout Agent collects the latest CVE disclosures from NVD, the GitHub Advisory Database, and OSV.dev, cross-referencing active threat pulses via AlienVault OTX; (2) the Triage Agent performs structured analysis using the CVSS v3.1 scoring standard, assigns CWE root-cause classifications, maps each vulnerability to relevant MITRE ATT&CK techniques, and computes a composite Urgency Score; (3) the Publisher Agent synthesizes the triaged data into this executive briefing. Every CVSS score is tagged with a Score Provenance label indicating whether it was confirmed against an official database (NVD or CNA record) or estimated by the analysis model when no official score existed. All CVE identifiers, CVSS scores, and CWE mappings are independently verifiable via the references provided in Section 5. References marked 'Fallback Search' indicate the specific CVE record was not found live at NVD or CVE.org at generation time; a source-database search link is provided instead. Severity classification follows the CVSS v3.1 standard: Critical (9.0-10.0), High (7.0-8.9), Medium (4.0-6.9), Low (0.1-3.9).

Primary Data Sources:

- NIST National Vulnerability Database (NVD) -- <https://nvd.nist.gov/>
- GitHub Advisory Database -- <https://github.com/advisories>
- OSV.dev Open Source Vulnerabilities -- <https://osv.dev/>
- CVE Services API (MITRE CNA Records) -- <https://cveawg.mitre.org/>
- OpenCVE -- <https://www.opencve.io/>
- AlienVault Open Threat Exchange (OTX) -- <https://otx.alienvault.com/>
- MITRE ATT&CK Framework -- <https://attack.mitre.org/>
- CVSS v3.1 Specification -- <https://www.first.org/cvss/v3.1/specification-document>
- Common Weakness Enumeration (CWE) -- <https://cwe.mitre.org/>
- CVE Program -- <https://www.cve.org/>